

Enterprise Risk Assessment

Waffarah E-Commerce Platform

Field	Detail
Prepared by	Joud Alhussain
Date	August 2026
Client	Waffarah (fictional engagement for portfolio purposes)
Classification	Confidential
Methodology	ISO/IEC 27005 Information Security Risk Management

1. Project Overview

This project conducts an enterprise risk assessment of Waffarah, a fictional mid-size e-commerce company, following the ISO/IEC 27005 information security risk management process. Unlike the technical penetration test performed in the companion Enterprise Security Assessment engagement, this assessment takes a broader governance and risk management view — covering people, process, technology, and third-party risk, not just the web application.

2. Business Scenario

Waffarah is a mid-size e-commerce company (~150 employees) handling customer orders and payment data. As part of maturing its security posture ahead of a compliance audit, Waffarah's leadership commissioned a formal information security risk assessment to identify, evaluate, and prioritize risks across the business — informing budget and resourcing decisions for the year ahead.

3. Objectives

- Identify Waffarah's key information assets and their business value
- Identify relevant threats and vulnerabilities for each asset
- Score and prioritize risks using a likelihood/impact risk matrix
- Produce a risk treatment plan with clear ownership and next steps
- Present findings in a business-readable format for leadership

4. Scope

In Scope

Information assets, systems, and processes core to Waffarah's e-commerce operations — customer data, payment processing, employee access, key third-party vendors, and physical premises security.

Out of Scope

Full technical penetration testing (covered separately in the Enterprise Security Assessment project), financial/market risk, and legal/contractual risk not related to information security.

5. Methodology

This assessment follows the ISO/IEC 27005 information security risk management process: context establishment, risk identification (asset-based), risk analysis, risk evaluation, and risk treatment. Assets were rated for Confidentiality, Integrity, and Availability (CIA) impact. Risks were scored using the same Likelihood × Impact severity matrix used in the Enterprise Security Assessment project, ensuring consistency across the portfolio.

Likelihood → / Impact ↓	Low	Medium	High
High	Medium	High	Critical
Medium	Low	Medium	High
Low	Low	Low	Medium

6. Asset Inventory

6.1 Data Assets

Data Asset	Description	C	I	A
Customer PII	Names, addresses, contact details	High	High	Medium
Payment card data	Stored/processed card details	Critical	High	High
Order & transaction history	Purchase records, order status	Medium	High	Medium
Employee HR data	Staff records, payroll info	High	Medium	Low
Authentication credentials	Passwords, session tokens, security questions	Critical	High	High
Product & pricing data	Catalog, pricing, inventory levels	Low	Medium	High
Customer support records	Complaint logs, communication history	Medium	Low	Low
Business/financial records	Revenue data, vendor contracts	High	High	Medium

6.2 Systems & Technology Assets

System/Technology Asset	Description	C	I	A
E-commerce web application	Customer-facing storefront (login, checkout, search)	Medium	High	Critical
Payment processing system	Handles transaction processing	Critical	Critical	Critical
Customer database	Stores customer accounts, PII, order history	High	High	High
Admin panel / back-office	Internal management of orders, users, inventory	High	High	Medium
Web/application servers	Infrastructure hosting the storefront and APIs	Medium	High	Critical
Employee endpoints	Staff devices with access to internal systems	Medium	Medium	Medium
IAM system	Manages employee/customer authentication and permissions	Critical	High	High
Backup systems	Backups of databases and critical files	High	High	High
Network infrastructure	Firewalls, routers, internal network	Medium	High	Critical

6.3 People & Process Assets

People/Process Asset	Description	C	I	A
Employee access credentials	Staff logins to admin panel, IAM, internal tools	High	High	Medium
Privileged/admin accounts	IT admin, database admin, and similar high-privilege roles	Critical	Critical	High
Onboarding/offboarding process	Granting and revoking employee system access	Medium	High	Medium
Incident response process	Detection, response, and recovery from security incidents	Medium	High	Critical
Vendor/third-party access	External parties with system access	High	High	Medium

People/Process Asset	Description	C	I	A
Physical access control	Badge access, visitor management	Medium	Medium	Medium
Security awareness & training	Employee understanding of phishing, social engineering	Low	Medium	Low

7. Risk Register

Risks were identified across all three asset categories and scored using the Likelihood × Impact matrix. Where possible, ratings were directly informed by confirmed findings from the Enterprise Security Assessment project rather than assumed — these are marked below.

ID	Asset	Threat	Likelihood	Impact	Rating
R1	Payment card data	Interception/compromise at rest or in transit	Medium	Critical	Critical
R2	Auth credentials	Exposed via misconfiguration (confirmed)	High	Critical	Critical
R3	Admin panel	Broken access control (confirmed — SQLi)	High	Critical	Critical
R4	Web application	Injection attacks SQLi/XSS (confirmed)	High	Critical	Critical
R5	Customer PII	Technical vulnerability exploitation	Medium	High	High
R6	Backup systems	Exposure via misconfiguration (confirmed)	High	High	High
R7	Payment processing	PCI DSS non-compliance	Medium	High	High
R8	Product/pricing data	Price manipulation (confirmed)	Medium	Medium	Medium
R9	Onboarding/offboarding	Delayed access revocation	Medium	Medium	Medium
R10	Customer PII	Data resale on black market	Medium	High	High
R11	Vendor access	Vendor account compromise	Low	High	Medium
R12	Employee HR data	Insider misuse of access	Low	Medium	Low-Medium
R13	Incident response	Inadequate/untested response plan	Medium	High	High
R14	Security awareness	Employee susceptibility to phishing	Medium	High	High
R15	Support records	Exposure of complaint details	Low	Low	Low

Severity breakdown: 4 Critical • 6 High • 3 Medium • 2 Low-Medium/Low

8. Risk Treatment Plan

ID	Risk	Treatment	Key Actions
R1	Payment card interception	Mitigate	TLS/HTTPS enforcement; tokenize card data; PCI DSS compliance program; mask card numbers
R2	Credentials exposed via misconfiguration	Mitigate	Disable directory listing; remove credential/backup files from web-accessible paths; automated scanning
R3	Admin panel broken access control	Mitigate	Parameterized queries; input validation; server-side role checks on every admin route
R4	Web app injection (SQLi/XSS)	Mitigate	Treat input as data not code; Content-Security-Policy header; regular security testing
R5	Customer PII exploitation	Mitigate	Secure coding app-wide; data minimization; purge on account deletion; mask PII in admin views
R6	Backup systems exposed	Mitigate	Remove backups from web paths; disable directory listing; encrypt backup files
R7	PCI DSS non-compliance	Mitigate	Formal gap assessment; assign compliance ownership; regular audits
R8	Price manipulation	Mitigate	Server-side transaction validation; real payment processor integration; anomaly detection
R9	Delayed access revocation	Mitigate	Automate revocation tied to HR process; least privilege from onboarding; periodic access reviews
R10	PII resale on black market	Mitigate	Dark web monitoring; breach notification plan; credit monitoring for affected customers
R11	Vendor compromise	Mitigate/Transfer	Least-privilege vendor access; contractual security requirements; regular vendor reviews
R12	HR data insider misuse	Mitigate	Role-based access restricted to HR/payroll; audit logging of HR record access
R13	Inadequate incident response	Mitigate	Formalize documented IR plan; regular tabletop exercises; post-incident review process
R14	Phishing susceptibility	Mitigate	Mandatory recurring training; simulated phishing campaigns; targeted follow-up training
R15	Support record exposure	Accept	Restrict full complaint text visibility to necessary staff; otherwise accepted

Treatment summary: 13 Mitigate • 1 Mitigate/Transfer • 1 Accept

8.1 Remediation Roadmap

Phase	Timeline	Key Actions
Immediate	0-30 days	Fix SQL injection (parameterized queries); disable directory listing; remove exposed backups/credentials; enforce server-side admin role checks
Short-term	30-90 days	PCI DSS gap assessment; formalize & test incident response plan; launch recurring security awareness training
Ongoing	Continuous	Quarterly access reviews; regular penetration testing; vendor security audits

9. Business Impact

Four Critical risks — SQL injection, credential exposure, admin panel access control, and payment card data protection — share overlapping root causes in input validation and access control, all independently confirmed during the Enterprise Security Assessment. Addressing these root causes resolves the majority of Waffarah's critical exposure in a single coordinated effort. The remaining High-severity risks span compliance (PCI DSS), organizational readiness (incident response, security awareness), and secondary harm (data resale, backup exposure) — areas requiring process and governance investment alongside technical fixes.

10. Lessons Learned

- Risk assessment and penetration testing reinforce each other. Several risk ratings in this project were directly validated by confirmed findings from the Enterprise Security Assessment, turning what could have been guesswork into evidence-based scoring.
- First-instinct ratings often need revision. Multiple risks (price manipulation, PII resale, security awareness) were initially underrated until tracing through the full consequence chain — a useful discipline to build deliberately rather than trust gut feeling alone.
- Not every “asset” is a physical thing. People and processes (onboarding, incident response, training) are legitimate ISO/IEC 27005 asset categories, and often the weakest link.
- Not every risk needs active mitigation. Consciously choosing to Accept a low-severity risk rather than over-investing in it is itself a valid, professional risk management decision.
- Root-cause thinking multiplies efficiency. Several Critical risks share the same underlying fix (input validation, access control), and recognizing that early avoids duplicated remediation effort.